

Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada — Seguridad de la Información | Dirigido al Directorio

Resumen Ejecutivo

Como parte del fortalecimiento del área de Seguridad de la Información, se realizó un relevamiento inicial de riesgos utilizando la herramienta SimpleRisk, motivado por hallazgos de una auditoría externa reciente. Se identificaron 7 riesgos concretos vinculados principalmente a la operación con personal tercerizado de alta rotación (soporte técnico, limpieza y facturación), un factor estructural de la organización que multiplica la exposición en varios frentes: control de accesos, manejo de datos de pacientes y continuidad operativa. De los 7 riesgos relevados, 1 se clasificó como Crítico y 5 como Altos, lo que representa el 86% del total y exige acción en el corto plazo.

Top 5 Riesgos por Nivel

ID	Riesgo	Nivel	Valor
R01	Acceso indebido de ex-personal tercerizado a historias clínicas	Crítico	16
R02	Ransomware propagado vía equipo de soporte externo	Alto	15
R03	Filtración de datos de pacientes por canales inseguros	Alto	12
R04	Pérdida de trazabilidad por cuentas compartidas	Alto	12
R07	Incumplimiento normativo por NDA no actualizados	Alto	12

Estado de los Planes de Acción

Plan	Riesgo asociado	Responsable	Vencimiento	Estado
A — Offboarding de accesos	R01	Jefe de Sistemas	30 días	Pendiente
B — Segmentación de red para terceros	R02	Jefe de Sistemas	60 días	Pendiente
C — Capacitación de onboarding	R03 / R07	RRHH / Compliance	45 días	Pendiente

Recomendaciones Prioritarias

- Formalizar e implementar de inmediato un proceso de **offboarding de accesos** para personal tercerizado, con baja el mismo día de finalización de contrato (mitiga R01, el único riesgo Crítico).
- Segmentar la red para todo acceso remoto de proveedores externos y exigir EDR en sus equipos, reduciendo la superficie de ataque frente a ransomware (R02).
- Exigir NDA individual —no solo a nivel de contrato marco con la tercerizadora— antes de otorgar acceso a cualquier sistema con datos de pacientes (R07).
- Incorporar una capacitación breve y obligatoria en manejo de datos sensibles como parte del onboarding de todo personal tercerizado, dada la alta rotación (R03).
- Adoptar una estrategia de backup 3-2-1 para no depender exclusivamente de un proveedor externo de copias de seguridad (R05).